

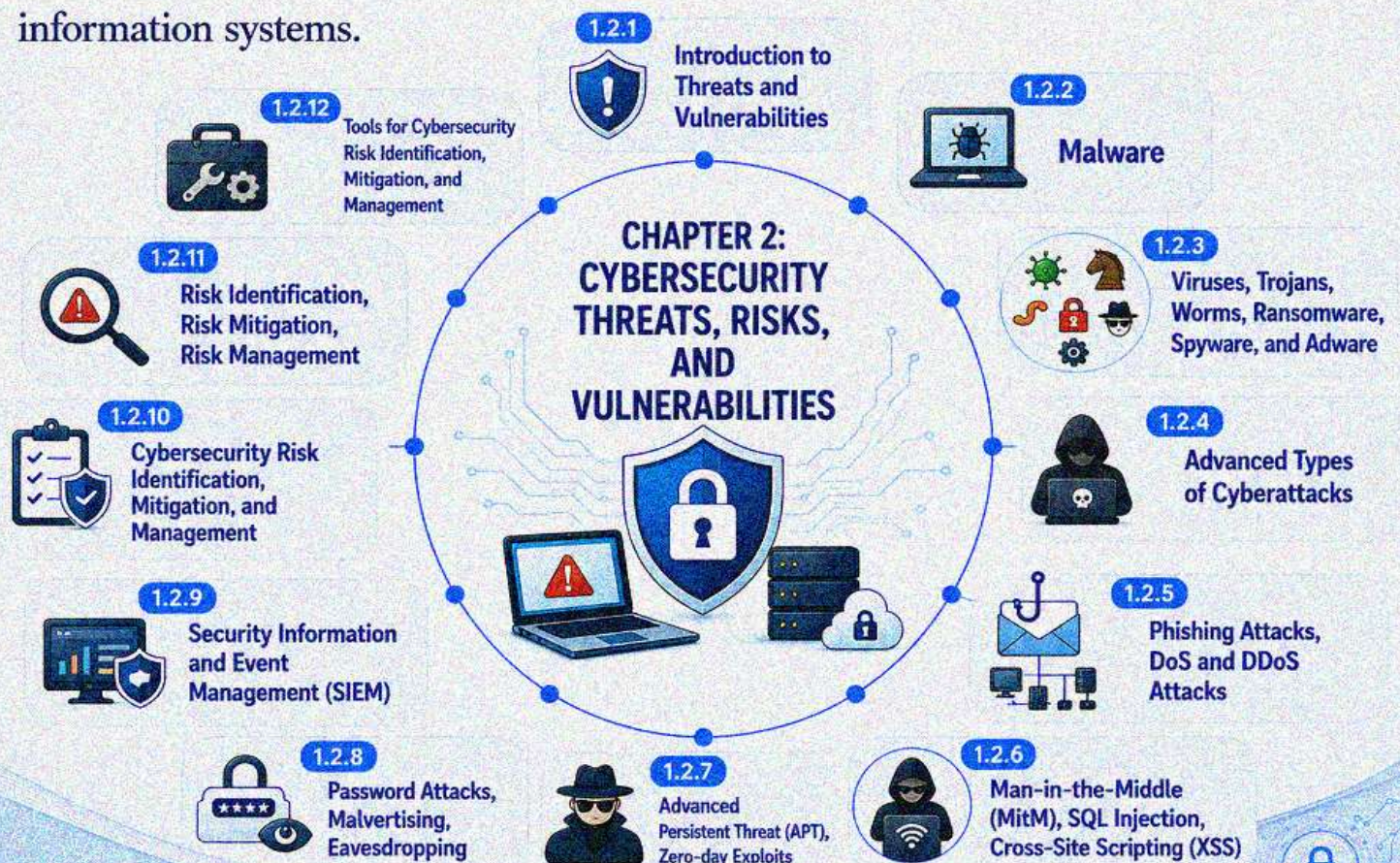
UNIT 1: FUNDAMENTALS OF CYBERSECURITY

CHAPTER 2: CYBERSECURITY THREATS AND RISKS

Chapter 2 introduces the cybersecurity risks, threats, and vulnerabilities affecting computers, networks, and digital information. It covers malware, phishing, DoS/DDoS, Man-in-the-Middle (MitM), SQL Injection, Cross-Site Scripting (XSS), Advanced Persistent Threats (APT), Zero-day exploits, Password attacks, and SIEM. Learners will understand cybersecurity risk identification, risk mitigation, and risk management techniques.

The chapter explains how attackers exploit vulnerabilities and how organizations apply preventive, detective, and corrective security controls. It also introduces Vulnerability Assessment and Penetration Testing (VAPT) for identifying security weaknesses before exploitation.

By the end of the chapter, learners will be able to recognize cyber threats, assess risks, and implement effective cybersecurity measures to protect digital assets and information systems.

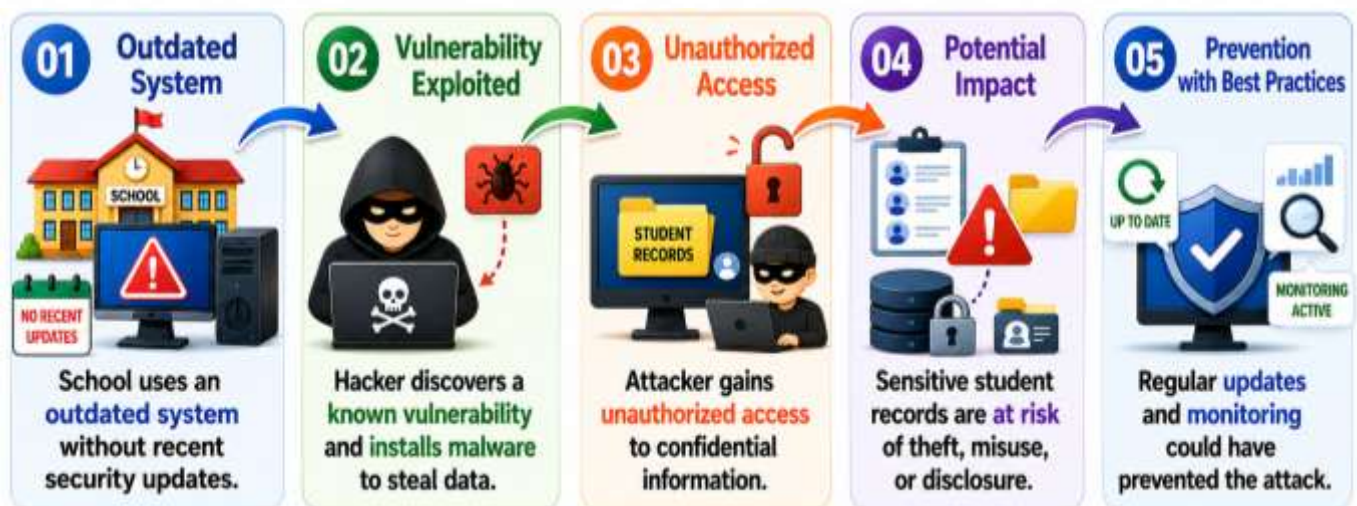




❖ 1.2.1 THREATS AND VULNERABILITIES

Cyber threat, in plain terms, is any incident, activity, or person that can harm a computer system, network, software, or digital information. A **vulnerability**, in cybersecurity terms, refers to a weakness or defect in hardware, software programs, network configurations, or even human behavior that can be exploited by an adversary (bad actor) to perform a cyberattack. Both threats and vulnerabilities go hand in hand with **Cybersecurity Risk Management**, which is why it is critical to understand them if organizations want to better protect themselves.

► **Example:** A school uses an outdated computer system that has not received recent **security updates**. A hacker discovers a known **software vulnerability** and installs **malware** to steal student records. Because the system was not patched, the attacker successfully gains unauthorized access to confidential information. If the school had installed the latest security patches and monitored its systems regularly, the attack could have been prevented.



■ Understanding Cyber Vulnerabilities

Cyber Threat simply refers to any potential danger or occurrence that may impact the confidentiality, integrity, or availability of an information system. Threats can come from hackers, cybercriminals, malicious insiders, or hacktivists. Some threats steal **Sensitive Information**, while others attempt to disrupt the operation of systems or services. Organizations that track threats from cybercriminals must stay vigilant to guard against emerging forms of attack, as these actors are always developing new ways to carry out attacks.

A **Vulnerability** is a weakness that reduces the security of a computer system or network. Vulnerabilities may exist in the operating system, software application, network device, security policy, or even user actions.



■ Common Sources of Vulnerabilities

As information systems have many components, cybersecurity vulnerabilities can exist in any of these parts. However, if spotted early, organizations can patch these **Vulnerabilities** before attackers discover and exploit them. Software bugs, weak passwords, human error, and **Misconfigured Security Settings** are common sources of vulnerabilities.

■ Software Vulnerabilities

When vulnerabilities occur in an application, **Operating System (OS)**, or firmware, they create weaknesses that can allow attackers to steal, view, or destroy data. Some of these vulnerabilities can allow an attacker to execute arbitrary code, bypass **Authentication**, or gain access to sensitive data. Developers regularly release **Security Updates** to patch these vulnerabilities. For example, one of the easiest things you can do to improve cybersecurity is to install updates promptly.

■ Weak Passwords

Weak Passwords or easily guessable passwords are among the most common security vulnerabilities. Therefore, guessable passwords like **nnnn12345** can be easily cracked using brute-force or dictionary attacks. A strong **Password** should contain uppercase letters, lowercase letters, numbers, and special characters.

■ Human Error

Human Error may unintentionally create security loopholes. People who open spam emails, click links from unfamiliar sources, share passwords over the Internet, or install unknown programs put an entire system at risk of **Cyber Threats**. Regular **Security Awareness** training is recommended so that users can identify suspicious activities and follow safe computing practices.

❖ 1.2.2 SOCIAL ENGINEERING

This type of **Threat** does not directly attack a computer or software system but manipulates people. Attackers use deception, psychological tricks, and **Manipulation** to achieve this. The main difference between social engineering and other common cyberattacks is that this technique exploits individuals rather than technology. The **Human Factor** is known to be the weakest link in **Cybersecurity**. Therefore, companies train their employees to identify and avoid these attacks through security awareness training.

► **Example:: How a Social Engineering (Phishing) Attack Happens:** An employee receives an email that appears to come from the company's IT department. The email asks the employee to urgently reset their password by clicking a link. Trusting the email, the employee clicks the link and opens a fake login page. The employee enters their username and password on the fake page. The cybercriminals steal the login credentials. The attackers then use the stolen credentials to access confidential company information.



Social Engineering Attack



Common Types of Social Engineering

Cybercriminals use a variety of **Social Engineering** methods to trick people into disclosing information or taking unsafe actions.

■ Phishing

One of the most common threats resulting from **Social Engineering** attacks is **Phishing**. In this method, attackers send fake emails, messages, or websites pretending to be from a trusted source such as a bank, school, or Internet service provider. These messages commonly ask users to verify their account, reset a password, or download an attachment. When people click a malicious **Link**, they may lose their login credentials, allowing attackers to install malware on their devices.

■ Vishing and Smishing

Vishing (Voice Phishing): Vishing has the same objective as phishing but is carried out over the telephone to persuade victims to reveal confidential information. Attackers may pretend to be bank representatives, technical support staff, or government officials.

Smishing (SMS Phishing): This method uses misleading text messages to persuade users to click an infected link or provide their personal information. These messages often appear to come from trusted organizations, such as banks, delivery services, or government agencies, to create a false sense of urgency. Users should avoid clicking suspicious links and verify the sender before responding or sharing any sensitive information.



■ Pretexting

Pretexting occurs when an attacker impersonates someone else or creates a believable story to obtain sensitive information. For example, an attacker may pose as a company IT administrator who "needs" the employee's username and password to fix a technical issue. Success depends on careful planning and convincing communication. To minimize the risk, organizations perform **Identity Verification** before granting access to sensitive data.

■ Baiting and Tailgating

Baiting tricks victims by offering something attractive, such as free software, music, or a USB device containing **Malware**. As a result, malware may install automatically when users open the infected file or connect the infected device. **Tailgating** occurs when an unauthorized person enters a restricted area by following an authorized employee.

■ Human Psychology in Social Engineering

Social Engineering exploits **Human Psychology** instead of technology, which is one of the reasons it is so successful. Attackers create messages that encourage victims to act before thinking carefully. Common psychological tactics include **Urgency**, trust, fear, curiosity, and rewards. For example, an email stating that an account will be permanently closed within one hour may cause users to panic and act quickly. Understanding these psychological tricks helps users reduce the risk of becoming victims of **Cybercrime** by making better decisions.

Common Types of Social Engineering



■ Preventing Social Engineering Attacks

User Education, social engineering awareness, and **Security Awareness** are important for protecting against cyber threats. User education is not the only way to protect against social engineering attacks—professional **Security** measures also make an impact. Organizations should regularly train employees to identify phishing emails, calls, and websites.

Do not click on **Links** sent by unknown users. Users should verify a **Website** before logging in. **Multi-Factor Authentication (MFA)** provides an extra layer of security even when passwords are compromised. Time is important; users should report **Suspicious Messages** immediately so that security teams can investigate, respond faster, and reduce the risk of attacks before they spread throughout the organization.

SESSION REVIEW



1.2.1 THREATS AND VULNERABILITIES

Understanding Cyber Vulnerabilities



- Weaknesses and dangers affecting information system security.

Common Sources of Vulnerabilities



- Software bugs, weak passwords, human error, and misconfigured security settings.

Software Vulnerabilities



- Weaknesses allowing attackers to steal, view, or destroy data.

Weak Passwords



- Easily guessable passwords easily cracked using brute-force or dictionary attacks.

Human Error



- Unintentionally creates security loopholes putting systems at risk.

1.2.2 SOCIAL ENGINEERING

Common Types of Social Engineering



- Methods to trick people into unsafe actions.

Phishing



- Fake emails, messages, or websites pretending to be trusted sources.

Vishing



- Phishing carried out over the telephone.

Smishing



- Misleading text messages persuading users to reveal personal information.

Pretexting



- Impersonating someone or creating a believable story.

Baiting



- Offering something attractive to trick victims.

Tailgating



- Unauthorized person enters a restricted area.

Human Psychology in Social Engineering



- Exploits human psychology instead of technology.

Preventing Social Engineering Attacks



- User education, awareness, and security measures protect against threats.